Q1.
Quelle est la différence entre assurer la sécurité et assuré la sûreté d’un système d’informations ?

R1.
Sécurité :
- Protection contre les actions malveillantes volontaires. Non quantifiable statiquement, mais il est possible **d’évaluer en amont le niveau de risque et les impacts.**

Sûreté :
- Protection contre les dysfonctionnements et accidents involontaires. Quantifiable statistiquement.

Q2.
Quelle sont les quatres principaux critères de l’évaluation de la sécurité d’un S.I ?

R2.
- **Confidentialité**
- **Intégrité**
- **Disponibilité**
- **Authenticité**

Q3.
Donner le niveau (bas, moyen, haut) nécessaire à assurer pour chacun des principaux critères de sécurité des S.I dans les deux cas suivants :
- Un système d’édition d’emploi de temps
- Un système de vente en ligne

R3.

Pour un système d'édition d'emploi de temps :

1. **Confidentialité** : Moyen (pour protéger les informations des employés)
2. **Intégrité** : Haut (pour éviter les erreurs dans les horaires)
3. **Disponibilité** : Haut (pour un accès constant)
4. **Authenticité** : Moyen à Haut (pour garantir l'identité des utilisateurs)

Pour un système de vente en ligne :

1. **Confidentialité** : Haut (pour protéger les données des clients)
2. **Intégrité** : Haut (pour des transactions précises)
3. **Disponibilité** : Haut (pour une accessibilité constante)
4. **Authenticité** : Haut (pour éviter la fraude)

Q4.
Quelle est la différence entre une attaque ciblé et une attaque non ciblé ? Donner des exemples de chaque types d'attaques

R4.
Attaque non Ciblé :
- Attaques contre des proies aleatoires.
- Utilisation de maliciels (malware).
- Vecteurs de propagation : e-mail, sites web contamines, SMS, etc.

Attaque Ciblé:
-Attaque contre une cible identifiée afin de compromettre une propriété de base de la sécurité de systèmes (intégrité, disponibilite, confidentialité, ...,etc.)

Q5.
Qu'est ce que l'hameçonnage (phishing) ? Donner quelques critères pour repérer un courriel d'hameçonnage.

R5.
Courrier dont l'expediteur se fait généralement passée pour un organisme demandant au destinataire de fournir des informations confidentielles
- Quelques critères pour repérer un courriel d'hameçonnage :

1. Demandes d'infos sensibles : Évitez de partager des informations confidentielles.
2. Liens suspects : Ne cliquez pas sur des liens douteux.
3. Erreurs linguistiques : Soyez vigilant face aux fautes d'orthographe ou de grammaire.
4. Urgence injustifiée : Méfiez-vous des demandes pressantes ou menaçantes.
5. Adresses d'expédition suspectes : Vérifiez attentivement les adresses e-mail des expéditeurs.

Q6.
Quelle est la différence entre un virus informatique, un vers informatique, un wabbit ?

R6.
- Virus informatique : Un programme capable de se répliquer et conçu pour se propager d'un ordinateur à un autre en s'insérant dans des logiciels légitimes, appelés **hôtes**.
- Vers informatique : Un programme capable de se répliquer et conçu pour se propager d'une manière autonome à travers les réseaux.
- Wabbit : Un programme capable de se répliquer mais ne possède pas la capacité de propagation dans les réseaux.

Q7.
Qu'est ce qu'une attaque de Déni de Service ? Donner un exemple concret

R7.
C'est une attaque qui permet de rendre le service lent ou indisponible.
- Exemple: Attack **TCP SYN flood** qui permet d'envoyer des paquets **TCP SYN** en masse afin de saturer la connexion.

Q8.
Le protocole IPv6 ne permet plus d'avoir un mode de diffusion don't la portée dépasse un réseau local. Expliquer l'intérêt de cette mesure d'un point de vue de sécurité des réseaux.

R8.
Limiter la portée des diffusions multicast à un réseau local en IPv6 réduit la surface d'attaque, empêche les attaques DDoS étendues, offre un meilleur contrôle du trafic réseau et protège les données sensibles en empêchant leur diffusion au-delà du réseau local.

Q9.
Des experts de sécurité proclament que les objets connectés représentent aujourd'hui une grande vulnérabilité pour les S.I. Discuter la véracité de cette proposition.

R9.
Les objets connectés présentent une grande vulnérabilité pour les systèmes d'information car ils sont souvent conçus sans suffisamment de mesures de sécurité, ce qui les rend faciles à pirater. Cela peut conduire à des risques de divulgation de données sensibles et de perturbation des opérations.

1. Sécurité minimale : Les objets connectés manquent souvent de sécurité.
2. Mises à jour difficiles : Les correctifs de sécurité sont souvent compliqués à installer.
3. Faible authentification : Certains dispositifs ont des mesures d'authentification faibles.
4. Multiplication des vulnérabilités : Chaque objet connecté est une porte d'entrée potentielle pour les attaquants.
5. Conséquences sérieuses : Les compromissions peuvent causer des fuites de données et des interruptions de service.

Q10.
Dans le domaine de la cybersécurité, qu'est ce qu'un **O.I.V** ? Donner des exemples.

R10.
O.I.V = Opérateur d'Importance Vitale
Exemple :
- Secteurs étatiques : civil, justice, militaire….
- Secteurs de la protection des citoyens : santé, gestion de l'eau, alimention
- Secteurs de la vie économique et sociale : énergie, communication, électronique, audiovisuel, information, transports, finances, industrie.

Q12.
Quelle est la différence entre un pare-feu et un IDS ? Donner des exemples de chaque types de systèmes.

R12.
Pare-feu : Un équipement, logiciel ou matériel, chargé de contrôler l'échange de paquets entre le réseau protégé et l'internet.
IDS (Système de détection d'intrusions) : Un équipement, logiciel ou matériel, qui automatise le processus d'analyse des événements d'un ordinateur/réseau pour y détecter des signes de problèmes de sécurité.

IDS détecte mais n’empêche pas les attaques.
Pare-feu détecte et empêche les attaques

Exemple : pare-feu logiciel (iptables sur les systèmes linux)

Q13.
Donner un exemple détaillé d’une attaque réseau par réflexion

R13.
Dans une attaque par réflexion :

1. L'attaquant falsifie l'adresse IP source des paquets qu'il envoie.
2. Il envoie des requêtes à des serveurs mal configurés, utilisant l'adresse IP de la cible comme source.
3. Les serveurs mal configurés répondent à la cible avec des réponses amplifiées.
4. La cible est submergée par le volume massif de trafic, la rendant indisponible pour les utilisateurs légitimes.

Q14.
Un administrateur système décide d'interdir l'envoi vers l'extérieur de son réseau tout paquet ICMP. Est ce une bonne décision ? argumenter votre réponse

R14.
Bloquer les paquets ICMP sortants peut renforcer la sécurité en réduisant la surface d'attaque et en préservant la confidentialité du réseau. Cependant, cela peut aussi compliquer le dépannage des problèmes de connectivité et perturber le fonctionnement de certains protocoles et applications qui en dépendent. La décision dépend des besoins spécifiques du réseau et des compromis entre sécurité, performance et compatibilité.

Q15.
L’utilisation du protocole TCP assure un bon niveau de sécurité de l'échange de l'information. Discuter la véracité de cette proposition.

R15.
Le protocole TCP assure une transmission fiable des données mais ne garantit pas leur sécurité. Il ne chiffre pas les données en transit ni n'authentifie les parties communicantes. Des mesures supplémentaires sont nécessaires pour assurer la sécurité, comme le chiffrement et l'authentification.

Q17.
On considère un routeur/pare-feu qui relie un réseau 192.168.1.0/24 à l'internet. Toutes les machines de ce réseau ont un accés sans restriction à tous les services sauf la machine 192.168.1.10 qui doit avoir un accés aux services **http seulement** (**ports 80 443**). Pour mettre en place cette politique la table de filtrage du pare-feu est configurée comme suit :

- **Si** @IP source = 192.168.1.10 & segment TCP & dport != 80 **Alors** Refuser.

- **Si** @IP source = 192.168.1.10 & segment TCP & dport != 443 **Alors** Refuser.

- **Si** @IP source != 192.168.1.10 **Alors** Accepter.

Q17.1
Est ce que la configuration proposée est conforme au cahier des charges ? Justifier votre réponse et proposer une correction si nécessaire.

R17.1
Non, le cahier des charges n'est pas respecté car la politique par défaut (**FORWARD, INPUT, OUTPUT**) n'est pas respecté.

- **Correction** :

- **Si** @IP source = 192.168.1.10 & segment TCP & dport = 80 **Alors Accepter**

- **Si** @IP source = 192.168.1.10 & segment TCP & dport = 443 **Alors Accepter**

- **Si** @IP source != 192.168.1.10 **Alors Accepter.**

Q17.2 Proposer une implémentation en utilisant l'application **iptables.**

R17.2

- **iptables -P FORWARD DROP**
- **iptables -P INPUT DROP**
- **iptables -P OUTPUT DROP**

- **iptables -A FORWARD** -s 192.168.1.10 -p tcp -dport 80 -j **ACCEPT**

- **iptables -A FORWARD** -s 192.168.1.10 -p tcp -dport 443 -j **ACCEPT**

- **iptables -A FORWARD** -s 192.168.1.10 -p tcp -sport 80 -j **ACCEPT**

- **iptables -A FORWARD** -s 192.168.1.10 -j **DROP**

Q18.

R18.

Vulnérabilité : Faiblesse au niveau d’un bien (au niveau de la conception, de la realisation, de l’installation, de la configuration ou de l’utilisation du bien).

Menace : Cause potentielle d’un incident, qui pourrait entrainer des dommages sur un bien si cette menace se concretisait.

Attaque : Une action qui vise a compromettre la sécurité d’un système.

Intrusion : Prise de controle, partielle ou totale d’un système distant.

Usurpation : (spoofing) la prise d’identité d’autrui (utilisateur ou système) afin de gagner une accés illégitime à un système.